

Guia Estudio Microtests Examen

Archivo: 001-Justificacion-motivacion-ciberseguridad.md

Idea clave: Tema 1 Ideaclave 1 (Justificacion y motivacion de la ciberseguridad)

Microtest: 1.1

1. El coste de realizar un ataque se denomina:

- **La respuesta:** b. Cost to break.
- **Justificación:** En el transcript, se menciona que *"el atacante no tiene que asumir un coste de ruptura"*, el cual en inglés se traduce como *cost to break*. Este coste representa el tiempo y recursos que el atacante debe invertir para vulnerar un sistema.

2. Para que la ciberseguridad sea rentable:

- **La respuesta:** b. Coste construcción defensas < (cost to fix + pérdida de beneficio + coste reconstrucción).
- **Justificación:** El professor explica que la inversión en ciberseguridad debe ser menor que las pérdidas potenciales si ocurre un ataque. Por lo tanto, la rentabilidad se logra cuando el coste de las defensas es inferior al conjunto de los costes derivados de un ataque exitoso (reparación, pérdida de beneficios y reconstrucción).

3. Del lado de la organización, los costes básicos son: coste de construcción de las medidas defensivas, coste de reparación de vulnerabilidades y...

- **La respuesta:** a. Coste de reconstrucción de sistemas.
- **Justificación:** En el transcript se indica que además del coste de construcción y reparación, existen "otros costes que incluyen el cálculo de las pérdidas derivadas y la reconstrucción de los sistemas", lo que confirma que el tercer coste principal es el de reconstrucción.

MicroTest 1.2

Archivo: 002-Amenazas-Riesgos-Ciberseguridad.md

Idea clave: Tema 1 - Idea clave 2 (Amenazas y riesgos de la ciberseguridad)

Microtest: 1.2

1. Al tipo de protesta con fines de activismo político, social o económico en forma de ataques cibernéticos. (Anonymous, Wikileaks...), se la denomina:

- **La respuesta:** c. Hacktivismo.
- **Justificación:** El *hacktivismo* combina "hacker" y "activismo", y se refiere al uso de ataques informáticos como forma de protesta o reivindicación política o social. Grupos como Anonymous o WikiLeaks actúan con esta motivación.

2. ¿Cuál es el ataque relacionado con los actores internos más frecuente?

- **La respuesta:** a. Phishing.
- **Justificación:** El *phishing* es uno de los ataques más comunes dentro de las organizaciones, ya que los empleados (actores internos) suelen ser víctimas de correos o mensajes falsos que buscan robar credenciales o instalar malware, aprovechando errores humanos o falta de capacitación.

3. Las APTs son características de:

- **La respuesta:** b. Actores estado.
- **Justificación:** Las *Amenazas Persistentes Avanzadas* (*APT*) son ataques sofisticados, prolongados y con alto nivel de recursos, generalmente patrocinados por estados o grupos vinculados a gobiernos, que buscan espionaje o control estratégico sobre redes críticas.

MicroTest 1.3

Archivo: 003-Dimensiones-de-Seguridad.md

Idea clave: Tema 1 - Idea clave 3 (Dimensions de la ciberseguridad)

Microtest: 1.3

1. ¿Cómo se puede asegurar la integridad de los sistemas?

- **La respuesta:** b. Firma digital avanzada.
- **Justificación:** La integridad busca garantizar que la información no sea alterada de forma no autorizada. Para ello, se utilizan mecanismos como la **firma digital avanzada**, que permite detectar cualquier modificación en los datos y asegurar que estos permanecen intactos desde su origen.

2. ¿Para qué es necesario un correcto diseño de logging o registro?

- **La respuesta:** a. Para garantizar la trazabilidad.
- **Justificación:** Un sistema de registro adecuado permite **rastrear las acciones y eventos** dentro de un sistema, identificando quién hizo qué y cuándo. Esto garantiza la **trazabilidad**, fundamental para detectar incidentes de seguridad y reconstruir lo ocurrido ante un ataque o fallo.

3. Proporcionar la prueba de que una determinada transmisión o recepción ha sido realizada, sin que su receptor/transmisor pueda negar que se haya producido, se denomina:

- **La respuesta:** d. No repudio.
- **Justificación:** El **no repudio** asegura que una persona no pueda negar la autoría o recepción de una acción o transacción. Se logra mediante mecanismos como la **firma digital avanzada**, que vincula de forma única al autor con la acción realizada.

MicroTest 1.4

Archivo: 004-Ciberseguridad-es-un-proceso.md

Idea clave: Tema 1 - Idea clave 4 (La ciberseguridad es un proceso)

Microtest: 1.4

1. Las descripciones sobre cómo configurar determinados elementos de seguridad para que sean aplicados de manera uniforme en toda la organización se denominan:
 - La respuesta: c. Líneas base
 - Justificación: Las **líneas base** son descripciones que establecen cómo deben configurarse los elementos de seguridad de manera uniforme en la organización, asegurando consistencia y cumplimiento de las políticas.
 2. Las descripciones detalladas de los pasos para llevar a cabo una determinada tarea por los usuarios sin dudas se llaman:
 - La respuesta: a. Procedimientos
 - Justificación: Los **procedimientos** describen paso a paso cómo realizar tareas específicas, permitiendo que los usuarios las ejecuten correctamente y sin ambigüedad.
 3. Los estándares, directrices y procedimientos son medios para implementar las:
 - La respuesta: A y C. Políticas
 - Justificación: Los **estándares, directrices y procedimientos** se utilizan como herramientas para **aplicar y cumplir las políticas de seguridad**, traduciendo los objetivos de alto nivel en acciones concretas y consistentes.
-

MicroTest 2.1

Archivo: 006-Politica-de-seguridad.md

Idea clave: Tema 2 - Idea clave 1 (Política de seguridad)

Microtest: 2.1

1. La política general de seguridad de una organización:
 - **La respuesta:** d. Todas las anteriores son correctas.
 - **Justificación:** La política general de seguridad define el comportamiento adecuado (qué se debe hacer), establece herramientas y procedimientos (cómo se aplican las medidas) y comunica un consenso sobre el uso de datos y aplicaciones dentro de la organización. Por tanto, todas las opciones anteriores forman parte de su propósito.
2. Un sistema de detección de intrusiones se usa en la fase de:
 - **La respuesta:** a. Monitorización.
 - **Justificación:** El sistema de detección de intrusiones (**IDS**) se utiliza para supervisar continuamente la red y detectar comportamientos sospechosos o ataques

en tiempo real. Su función principal pertenece a la fase de **monitorización** dentro del ciclo de gestión de la seguridad.

3. Un cortafuegos se instala en la fase de:

- **La respuesta:** c. Implementación.
- **Justificación:** Los cortafuegos (firewalls) se configuran y despliegan durante la fase de **implementación**, cuando se establecen las medidas y controles de seguridad iniciales que protegerán la red y los sistemas frente a accesos no autorizados.

MicroTest 2.2

Archivo: 007-Diseno-de-politca-seguridad.md

Idea clave: Tema 2 - Idea clave 2 (Diseno de la politica de seguridad)

Microtest: 2.2

1. El tipo de norma que estandariza el uso de aspectos específicos del sistema (indican un uso correcto y responsabilidad del usuario y son obligatorias) se denomina:

- **La respuesta:** b. Estándar
- **Justificación:** Los **estándares de seguridad** establecen reglas obligatorias sobre el uso correcto de los sistemas, definiendo responsabilidades y comportamientos esperados de los usuarios. Su propósito es asegurar la uniformidad en la aplicación de las medidas de seguridad y garantizar que todos sigan las mismas pautas operativas.

2. El tipo de norma destinada a ayudar a los usuarios a aplicar las medidas de seguridad correctamente al proporcionar un razonamiento donde no se dispone de los procedimientos correctos, se denomina:

- **La respuesta:** c. Guía de seguridad
- **Justificación:** Las **guías de seguridad** sirven como orientación o referencia para los usuarios, ofreciendo recomendaciones prácticas sobre cómo aplicar medidas de seguridad. No son obligatorias, pero ayudan a mantener buenas prácticas cuando no existen procedimientos formales definidos.

3. El tipo de norma que se ocupa de tareas específicas, mostrando cada paso que se debe realizar y que es muy útil en tareas que son repetitivas, como en un procedimiento de backup y recuperación, se denomina:

- **La respuesta:** a. Procedimientos de seguridad
- **Justificación:** Los **procedimientos de seguridad** detallan de manera sequential las acciones a seguir en tareas concretas, garantizando que se realicen de forma correcta y consistente. Son esenciales en operaciones críticas o repetitivas, como copias de seguridad o gestión de incidentes.

MicroTest 2.3

Archivo: 008- SGSI .md

Idea clave: Tema 2 - Idea clave 3 (Sistema de gestion de seguridad de la information)

Microtest: 2.3

1. Un sistema de gestión para la seguridad de la información:

- **La respuesta:** d. Todas las anteriores son correctas.
- **Justificación:** Un **SGSI** (Sistema de Gestión de Seguridad de la Información) establece políticas y planes de seguridad, **opera y mantiene** los procesos definidos, y **mide los resultados** mediante indicadores de desempeño. Todo esto forma parte de su ciclo de mejora continua (**PDCA**), que integra planificación, ejecución, verificación y mejora.

2. ¿Cuál es la actividad más importante en un **SGSI** ?

- **La respuesta:** c. Análisis y gestión de riesgos.
- **Justificación:** El **análisis y gestión de riesgos** es el eje central del **SGSI** , ya que permite identificar, evaluar y tratar los riesgos que pueden afectar los activos de información. A partir de esta actividad se determinan las salvaguardas necesarias y se orientan todas las decisiones de seguridad dentro del sistema.

3. La declaración de aplicabilidad de salvaguardas es propia de la fase (**ISO27001**):

- **La respuesta:** c. **PLAN** : tratamiento de los riesgos.
- **Justificación:** En la norma **ISO 27001**, la **Declaración de Aplicabilidad (SOA)** se elabora durante la fase de **planificación del tratamiento de riesgos**, ya que en este documento se detallan las salvaguardas seleccionadas, su justificación y su prioridad de implementación para reducir los riesgos identificados.

MicroTest 2.4

Archivo: 009-Profesion-de-gestion-ciberseguridad.md

Idea clave: Tema 2 - Idea clave 4 (Profesion de gestion de la ciberseguridad)

Microtest: 2.4

1. Una profesión puede caracterizarse por el desarrollo de algunos de los siguientes criterios:

- **La respuesta:** d. Todas las anteriores son ciertas.
- **Justificación:** Una profesión se define por varios criterios en conjunto: un cuerpo organizado de conocimientos, el reconocimiento de su utilidad y autoridad por parte de la comunidad y los clientes, un código ético y una cultura profesional.

2. El hacker ético tiene como elemento interesante el situar:

- **La respuesta:** b. La seguridad desde el contexto del atacante.

- **Justificación:** El hacker ético analiza la seguridad poniéndose en el lugar del atacante para detectar vulnerabilidades antes de que puedan ser explotadas de forma maliciosa.
3. Un ejemplo de recopilación de requisitos en el área (que puede considerarse como definitorio) de qué debe saber un profesional de la seguridad de la información sería:
- **La respuesta:** c. El cuerpo de conocimiento (body of knowledge, **BoK**) del Consorcio Internacional de Certificación de Seguridad de Sistemas de Información o (**ISC**)².
 - **Justificación:** El BoK del (**ISC**)² define los dominios y competencias esenciales que debe dominar un profesional certificado en seguridad de la información, siendo una referencia internacional reconocida.
-

MicroTest 2.5

Archivo: 010-certificaciones-de-ciberseguridad.md

Idea clave: Tema 2 - Idea clave 5 (Certificaciones de ciberseguridad)

Microtest: 2.5

1. La certificación Certified Information Systems Security Professional (**CISSP**) es certificada por:
 - **La respuesta:** d. International Information Systems Security Certification Consortium.
 - **Justificación:** El (**ISC**)² (**International Information Systems Security Certification Consortium**) es la organización internacional que otorga la certificación **CISSP**, reconocida globalmente como un estándar para profesionales de la seguridad de la información.
2. La certificación Certified Information Systems Security Professional (**CISSP**), incluye:
 - **La respuesta:** d. Todas las anteriores son correctas.
 - **Justificación:** El **CISSP** se compone de tres subespecializaciones:
 - **ISSAP** (Arquitectura de seguridad),
 - **ISSEP** (Ingeniería de seguridad), y
 - **ISSMP** (Gestión de seguridad).
 Todas forman parte del cuerpo de conocimiento de **CISSP** y permiten especializarse en distintas áreas de la ciberseguridad.
3. Un **CISSP** está certificado como profesional para:
 - **La respuesta:** a. Definir la arquitectura de seguridad.
 - **Justificación:** El **CISSP** acredita a un profesional con la capacidad de **diseñar, definir y gestionar arquitecturas de seguridad**, así como implementar controles en sistemas y redes. Aunque puede tener nociones de desarrollo o auditoría, su

función principal es la **definición y gestión integral de la seguridad de la información**.

MicroTest 3.1

Archivo: 012-Principales-metodologias-y-herramientas.md

Idea clave: Tema 3 - Idea clave 1 (Principales metodologías y herramientas)

Microtest: 3.1

1. ¿Cuál es una desventaja de **OCTAVE** ?

- **La respuesta:** c. Implica un elevado nivel de conocimientos tecnológicos y técnicos.
- **Justificación:** Una de las principales desventajas de **OCTAVE** es que su correcta aplicación requiere un alto nivel de comprensión técnica y comunicación dentro del equipo, lo cual puede dificultar su implementación en organizaciones con poca experiencia en gestión de riesgos.

2. ¿Cuál es la principal desventaja de **MAGERIT** ?

- **La respuesta:** A. No establece explícitamente la identificación de vulnerabilidades como uno de los pasos de la metodología.
- **Justificación:** **MAGERIT** no incluye de manera explícita la identificación de vulnerabilidades como paso dentro de la metodología (A) y presenta dificultad para traducir valoraciones cualitativas en cuantitativas o económicas (B). Ambas características son consideradas desventajas clave.

3. **MAGERIT** está basada en las normas:

- **La respuesta:** D: Todas las anteriores son correctas.
 - **Justificación:** **MAGERIT** se fundamenta principalmente en normas internacionales como **ISO 31000** y **ISO / IEC 27001**, que establecen los requisitos para la gestión de la seguridad de la información. Aunque guarda relación conceptual con otras normas **ISO** , su base formal se alinea con **ISO 27001**.
-

MicroTest 3.2

Archivo: 013-Planificacion-de-analisis-de-riesgos.md

Idea clave: Tema 3 - Idea clave 2 (Planificación de un proyecto de análisis de riesgos)

Microtest: 3.2

1. ¿En qué fase se realiza la toma de decisiones?

- **La respuesta:** b. Gestión de riesgos.
- **Justificación:** La toma de decisiones se lleva a cabo en la fase de **gestión de riesgos**, ya que es en este momento cuando se definen las estrategias de

mitigación, se seleccionan las salvaguardas y se determinan las acciones a implementar para reducir los riesgos identificados en la fase de análisis.

2. En el comité de dirección existe la figura del:

- **La respuesta:** d. Promotor.
- **Justificación:** El **promotor** pertenece al comité de dirección y es quien impulsa el proyecto, determina la oportunidad de su inicio y elabora el informe preliminar antes de la creación del comité de seguimiento, siendo una figura clave en la fase de planificación.

3. El director del proyecto y su equipo planifican toda la realización del proyecto a través de:

- **La respuesta:** d. Todas las anteriores son correctas.
- **Justificación:** La planificación del proyecto incluye la elaboración del **plan de entrevistas**, la **identificación de los participantes** a entrevistar y la definición del **calendario**, por lo que las tres opciones forman parte del proceso completo de planificación.

MicroTest 3.3

Archivo: 014-Analisis-de-riesgos.md

Idea clave: Tema 3 - Idea clave 3 (Analysis de riesgos)

Microtest: 3.3

1. El impacto es igual a:

- **La respuesta:** b. Degradación del valor del activo.
- **Justificación:** El impacto representa la **pérdida o degradación del valor de un activo** cuando una amenaza se materializa. Es la consecuencia directa del daño que sufre el activo, y no depende del riesgo acumulado o la frecuencia, sino del efecto sobre su valor.

2. El actor o agente que es la fuente de peligro por diferentes motivaciones como factores económicos, de prestigio u otros, se denomina:

- **La respuesta:** c. Amenaza.
- **Justificación:** Una **amenaza** es cualquier agente o evento que puede causar daño a un activo. Puede tener diversas motivaciones económicas, políticas o personales y, si se materializa, puede provocar un impacto negativo en la organización.

3. ¿Cómo hay que valorar una salvaguarda?

- **La respuesta:** c. En base a su eficacia medida en cómo la salvaguarda está implantada.
- **Justificación:** Las **salvaguardas** se valoran según su **eficacia real**, es decir, por el grado en que están implementadas y su capacidad para reducir la probabilidad o el

impacto de una amenaza. No basta con conocer su costo, sino con evaluar su efectividad dentro del sistema de seguridad.

MicroTest 3.4

Archivo: 015-Gestion-de-Riesgos.md

Idea clave: Tema 3 - Idea clave 4 (Gestion de riesgos)

Microtest: 3.4

1. ¿Cuál es la solución ideal para mitigar el riesgo?
 - **La respuesta:** a. Evitarlo.
 - **Justificación:** La **solución ideal** frente a un riesgo es **evitarlo**, eliminando la causa o la amenaza antes de que pueda materializarse. Aunque no siempre es posible, representa la opción más segura, ya que suprime totalmente la exposición al riesgo.
 2. Debe haber un programa de seguridad para:
 - **La respuesta:** c. Cada escenario de impacto para dar respuesta.
 - **Justificación:** La gestión del riesgo establece que se debe diseñar un **programa de seguridad específico para cada escenario de impacto y riesgo crítico**, con el fin de proporcionar una **respuesta adecuada** y adaptada a las características del activo y la amenaza involucrada.
 3. Los aspectos que definir en la gestión del riesgo son:
 - **La respuesta:** d. Todas las anteriores son correctas.
 - **Justificación:** La gestión del riesgo debe incluir **objetivos claros, salvaguardas concretas con criterios de eficacia y eficiencia**, y la **identificación de escenarios de impacto y riesgos**, incluyendo los activos y amenazas implicadas. Todos estos elementos son esenciales para elaborar un plan de seguridad completo y efectivo.
-

MicroTest 3.5

Archivo: 016-Herramienta-Pilar.md

Idea clave: Tema 3 - Idea clave 5 (Herramienta **PILAR**)

Microtest: 3.5

1. La fase de análisis de riesgos con **PILAR** comporta las siguientes actividades:
 - **La respuesta:** d. Todas las anteriores son correctas.
 - **Justificación:**
La herramienta **PILAR** , dentro de la metodología **MAGERIT** , contempla en la fase de análisis de riesgos la **identificación y valoración de activos, amenazas y**

salvaguardas. Estas tres actividades son fundamentales para determinar el nivel de riesgo y establecer estrategias de mitigación adecuadas.

2. Señale la respuesta correcta. El coste de las salvaguardas debe ser inferior a:

- **La respuesta:** c. La estimación de las pérdidas.
- **Justificación:**

En gestión de riesgos, la implantación de una salvaguarda solo es viable si su **coste es menor que las pérdidas potenciales que evita**. Invertir más en protección que lo que se perdería sin ella sería ineficiente desde el punto de vista económico y de gestión.

3. Los perfiles de seguridad que incorpora la herramienta **PILAR** son:

- **La respuesta:** d. Todas las anteriores son ciertas.
- **Justificación:**

PILAR incluye **múltiples perfiles normativos de seguridad**, entre ellos **ISO 27002:2013**, **GDPR (Reglamento General de Protección de Datos)** y el **ENS (Esquema Nacional de Seguridad)**. Esto permite adaptar el análisis y tratamiento de riesgos a diferentes marcos regulatorios y contextos organizativos.

MicroTest 4.1

Archivo: 018-Ciclo-de-vida- **SSDLC** .md

Idea clave: Tema 4 - Idea clave 1 (Ciclo de vida de desarrollo seguro de software - **SSDLC**)

Microtest: 4.1

1. ¿En qué fase se debe realizar un test de penetración a una app web?

- **La respuesta:** c. Pruebas.
- **Justificación:** El test de penetración forma parte de la **fase de pruebas y despliegue** del **SSDLC** , donde se evalúa la seguridad del sistema antes de su paso a producción. En esta etapa se ejecutan pruebas funcionales y de penetración (de caja negra o blanca) para detectar vulnerabilidades que no fueron identificadas en fases previas.

2. La derivación de requisitos de seguridad depende de:

- **La respuesta:** d. Las opciones A y B.
- **Justificación:** Los **requisitos de seguridad** se derivan a partir del **modelado de amenazas o casos de abuso** y del **análisis de riesgos**. Estas dos actividades previas permiten identificar las amenazas potenciales y evaluar su impacto, lo que define las medidas de seguridad que deben implementarse.

3. Antes del test de penetración, ¿qué actividades de seguridad hay que llevar a cabo?

- **La respuesta:** d. Todas las opciones anteriores son correctas.
- **Justificación:** Antes de realizar un test de penetración se deben haber completado la **derivación de requisitos de seguridad**, el **modelado de amenazas** y el **análisis**

de seguridad del código fuente. Estas actividades garantizan que el sistema esté preparado y que las pruebas de penetración se enfoquen en los riesgos y vulnerabilidades más relevantes.

MicroTest 4.2

Archivo: 019-Arquitecturas-de-las-apps-web.md

Idea clave: Tema 4 - Idea clave 2 (Arquitecturas de las apps web)

Microtest: 4.2

1. Los web services son un tipo de arquitectura:

- **La respuesta:** c. SOA .
- **Justificación:** Los **web services** pertenecen a la **arquitectura orientada a servicios (SOA)**, donde los components actúan como **proveedores y consumidores de servicios** distribuidos. Su objetivo es permitir la comunicación entre aplicaciones a través de protocolos estándar como HTTP , SOAP o REST .

2. ¿Qué tipo de aplicaciones móviles tienen más limitado el acceso a los dispositivos físicos del móvil?

- **La respuesta:** b. Basadas en navegador.
- **Justificación:** Las **aplicaciones basadas en navegador** se ejecutan dentro del navegador web del dispositivo (por ejemplo, en HTML5 y JavaScript) y, por tanto, **tienen acceso restringido al hardware** del móvil, a diferencia de las **nativas o híbridas**, que pueden interactuar directamente con components como la cámara o el micrófono.

3. En la arquitectura clásica de aplicaciones web, ¿Dónde se genera la capa de presentación?

- **La respuesta:** c. Servidor de aplicaciones.
 - **Justificación:** En una **arquitectura clásica**, la **capa de presentación** (las vistas que el usuario ve en el navegador) se genera en el **servidor de aplicaciones**, que procesa las solicitudes del cliente, aplica la lógica de negocio y devuelve las páginas renderizadas al navegador. En cambio, en arquitecturas RIA , la presentación se genera en el cliente.
-

MicroTest 4.3

Archivo: 020-Arquitecturas-de-apps-ajax.md

Idea clave: Tema 4 - Idea clave 3 (Arquitecturas de apps AJAX)

Microtest: 4.3

1. ¿Qué método se suele usar en las arquitecturas de aplicaciones **AJAX** para comunicación con el servidor?
 - **La respuesta:** d. `xmlHttpRequest()` .
 - **Justificación:** En **AJAX** , la comunicación entre el cliente (navegador) y el servidor se realiza mediante el objeto `XMLHttpRequest()` , que permite enviar y recibir datos de forma asíncrona sin recargar la página completa. Este método encapsula las peticiones **HTTP** (como **GET** o **POST**) para intercambiar información entre ambos extremos.
 2. ¿Qué tecnologías usa la arquitectura de aplicaciones **AJAX** ?
 - **La respuesta:** d. Todas las anteriores son correctas.
 - **Justificación:** La arquitectura **AJAX** combina varias tecnologías: **HTML** para la estructura de la página, **JavaScript** para la lógica y manejo dinámico de datos, y **XML** (u otros formatos como **JSON**) para el intercambio de información con el servidor. La integración de estas tecnologías permite crear aplicaciones web interactivas y dinámicas.
 3. En la arquitectura **RIA** de aplicaciones web, ¿dónde se genera la capa de presentación?
 - **La respuesta:** a. Navegador.
 - **Justificación:** En las **RIAs (Rich Internet Applications)**, la capa de presentación se genera en el **lado del cliente**, es decir, en el **navegador**. A diferencia de la arquitectura clásica, donde el servidor produce la vista, en **RIA** la lógica y renderización se realizan en el cliente usando frameworks como **Angular, React o Vue**, mejorando la velocidad y experiencia del usuario.
-

MicroTest 4.4

Archivo: 021-Protocolo- **HTTP** .md

Idea clave: Tema 4 - Idea clave 4 (Protocolo **HTTP**)

Microtest: 4.4

1. ¿Qué método **HTTP** permite conectarse a un servicio situado detrás de un proxy?
 - La respuesta: d. **CONNECT** .
 - Justificación: El método **CONNECT** se utiliza para crear un túnel a través de un proxy, permitiendo al cliente conectarse a un servicio que se encuentra detrás de dicho proxy, como servidores internos o servicios no accesibles directamente.
2. ¿Qué método **HTTP** permite obtener solo las cabeceras de la aplicación web?
 - La respuesta: b. **HEAD** .
 - Justificación: El método **HEAD** es equivalente a **GET** , pero el servidor responde únicamente con las cabeceras **HTTP** , sin incluir el cuerpo del mensaje, lo que permite verificar metadatos del recurso.

3. ¿Qué método HTTP envía los parámetros en la URL ?

- La respuesta: a. GET .
- Justificación: El método GET envía los parámetros concatenados directamente en la URL mediante el uso de ? y & , lo que hace que los datos sean visible en la barra de direcciones, historial y logs del navegador.

MicroTest 5.1

Archivo: 023-Vulnerabilidades-OWASP -2021.md

Idea clave: Tema 5 - Idea clave 1 (Vulnerabilidades OWASP Top Ten 2021: XSS , SQLI)

Microtest: 5.1

1. ¿Cómo se previene XSS ?

- La respuesta: d. B y C son correctas.
- Justificación: XSS se previene principalmente mediante la **codificación de la salida** para evitar que el navegador interprete código JavaScript inyectado y mediante la **validación de la entrada**, evitando que se introduzcan payloads maliciosos. Aunque las consultas parametrizadas se asocian más a SQLi, forman parte de una correcta validación de entradas.

2. ¿Qué vectores de entrada se pueden usar para intentar XSS ?

- La respuesta: d. Todas las anteriores son correctas.
- Justificación: XSS puede explotarse a través de **enlaces enviados por correo**, **campos de formularios** y **cualquier enlace parametrizado**, siempre que la aplicación refleje el contenido sin validación adecuada.

3. ¿Cuál es un ejemplo de payload XSS ?

- La respuesta: a. `<script>alert("hacked")</script>` .
- Justificación: Este payload inyecta código JavaScript que se ejecuta en el navegador de la víctima, lo cual es característico de un ataque XSS . Las otras opciones corresponden a inyección SQL y traversal de directorios, no a XSS .

MicroTest 5.2

Archivo: 024-Vulnerabilidades-OWASP - LFI - RFI .md

Idea clave: Tema 5 - Idea clave 2 (Vulnerabilidades OWASP Top Ten 2021: HTTP Response Splitting, LFI , RFI)

Microtest: 5.2

1. La vulnerabilidad LFI o inclusión de ficheros...

- La respuesta: d. Las opciones A y C son correctas.

- Justificación: **LFI** permite **acceder a recursos del sistema de ficheros no permitidos**, como archivos de configuración o del sistema operativo, y como consecuencia de ello puede **facilitar el robo de credenciales** u otra información sensible almacenada en dichos ficheros.
2. ¿Qué vectors de entrada se pueden usar para intentar explotar **LFI** ?
- La respuesta: c. Todas las opciones son correctas.
 - Justificación: **LFI** puede explotarse mediante **parámetros en enlaces, campos de formularios y enlaces debidamente parametrizados desde cualquier ubicación**, siempre que la aplicación no valid correctamente la ruta del fichero.
3. ¿Cuál es un ejemplo de payload de **RFI** ?
- La respuesta: d. enlace eliminado (enlace eliminado) = enlace eliminado (enlace eliminado).
 - Justificación: Un ataque **RFI** consiste en **incluir un recurso remoto** alojado en otro servidor mediante una **URL** externa, lo que permite incrustar contenido remoto en la aplicación web vulnerable.

MicroTest 5.3

Archivo: 025-Vulnerabilidades- **OWASP** -Hardcoded-password.md

Idea clave: Tema 5 - Idea clave 3 (Vulnerabilidades **OWASP** Top Ten 2021: Hardcoded Password, Session Fixation, **SSRF**)

Microtest: 5.3

1. ¿Por qué motivo se puede dar un ataque de suplantación en una aplicación web mediante fijación de sesión?
- La respuesta: a.
 - Justificación: La fijación de sesión ocurre cuando la aplicación entrega un **ID** de sesión antes de que el usuario se autentique correctamente, lo que permite que un atacante fije ese **ID** y luego lo reutilice cuando la víctima inicia sesión.
2. ¿Cómo se puede conseguir explotar Server Side Request Forgery?
- La respuesta: a.
 - Justificación: El ataque **SSRF** se explota manipulando parámetros de entrada (normalmente en formularios) que la aplicación utilice para construir URLs, provocando que el servidor realice peticiones a servicios internos o externos controlados por el atacante.
3. ¿Cómo se puede mitigar la vulnerabilidad Server Side Request Forgery?
- La respuesta: b.
 - Justificación: La mitigación principal del **SSRF** es la validación de entrada, permitiendo únicamente URLs o destinos previamente autorizados mediante listas blancas y bloqueando accesos no permitidos.

MicroTest 5.4

Archivo: 026-Vulnerabilidades-Owasp- CSRF -Open-redirect.md

Idea clave: Tema 5 - Idea clave 4 (Vulnerabilidades OWASP Top Ten 2013: CSRF y Open Redirect)

Microtest: 5.4

1. ¿Cómo se previene CSRF ?

- La respuesta: d. Token anti- CSRF .
- Justificación: El token anti- CSRF es un identificador único y temporal que se incluye en cada petición sensible y se valida en el servidor. Esto evita que peticiones forjadas desde sitios externos tengan éxito, ya que el atacante no puede conocer ni reutilizar un token válido.

2. La vulnerabilidad redirección no validada (open redirect):

- La respuesta: d. Permite redirigir al usuario víctima a un sitio web no esperado.
- Justificación: La redirección no validada ocurre cuando la aplicación no valida correctamente los parámetros de redirección, permitiendo que un atacante envíe al usuario a un sitio externo no previsto, lo que puede ser usado para phishing o robo de credenciales.

3. ¿Cuál es un ejemplo de payload de CSRF ?

- La respuesta: d. Ninguna de las anteriores.
- Justificación: Los ejemplos dados corresponden a otras vulnerabilidades (XSS , SQL Injection y Path Traversal). Un ataque CSRF no se basa en un payload típico de inyección, sino en una petición legítima forjada que aprovecha una sesión autenticada del usuario.

MicroTest 6.1

Archivo: 028-Authicacion-http-basic-digest.md

Idea clave: Tema 6 - Idea clave 1 (Autenticacion HTTP Basic - Digest)

Microtest: 6.1

1. ¿Cómo envía el método Basic las credenciales al servidor de aplicaciones?

- La respuesta: c. Codificadas Base64.
- Justificación: El método HTTP Basic envía el usuario y la contraseña en cada petición dentro de la cabecera Authorization, codificados en Base64, lo cual no implica cifrado y permite recuperar fácilmente las credenciales.

2. ¿Qué ataques puede sufrir Basic?

- La respuesta: a. Repetición.

- Justificación: Debido a que las credenciales se envían siempre de la misma forma en cada petición, un atacante puede capturar una petición válida y reenviarla posteriormente para autenticarse sin conocer la contraseña.

3. ¿Cómo envía Digest las credenciales al servidor de aplicaciones?

- La respuesta: d. HASH MD5 .
- Justificación: En la autenticación HTTP Digest no se envía la contraseña directamente, sino un valor hash (tradicionalmente MD5) calculado a partir del usuario, la contraseña, el nonce y otros parámetros, que el servidor puede verificar recalculándolo.

MicroTest 6.2

Archivo: 029-Kerberos.md

Idea clave: Tema 6 - Idea clave 2 (Autenticacion NTLM - Kerberos)

Microtest: 6.2

1. ¿Cómo envía NTLM las credenciales al servidor de aplicaciones?

- La respuesta: b. HMAC - MD5 .
- Justificación: NTLM no envía la contraseña en claro ni cifrada, sino que utiliza un esquema de desafío–respuesta donde calcula valores criptográficos (LMv2 y NTLMv2) mediante HMAC - MD5 a partir del hash de la contraseña y un nonce enviado por el servidor.

2. ¿Qué ataque es típico contra Kerberos?

- La respuesta: d. Todas las anteriores son correctas.
- Justificación: Kerberos puede ser atacado mediante Golden Ticket, Silver Ticket y Kerberoasting, todos ellos descritos como ataques específicos del protocolo que explotan una mala gestión de cuentas, claves o tickets.

3. NTLM calcula 2 parámetros que son:

- La respuesta: a. LMV2 y NTV2 .
- Justificación: NTLMv2 calcula dos respuestas principales, LMv2 y NTLMv2, que se generan usando HMAC - MD5 y combinan el hash de la contraseña, el dominio, el usuario y los desafíos cliente-servidor.

MicroTest 6.3

Archivo: 030-Autenticación- OAUTH2 - OPENID - CONNECT .md

Idea clave: Tema 6 - Idea clave 3 (Autenticacion OAuth2 OpenID Connect)

Microtest: 6.3

1. OAUTH2 usa:

- La respuesta: c. La A y la B.
- Justificación: OAuth 2.0 utiliza un **código de autorización** para obtener posteriormente un **token de acceso**, separando el proceso de autenticación del acceso al recurso protegido.

2. ¿De qué tipo son el token y el código de autorización en OAUTH2 ?

- La respuesta: c. JWT .
- Justificación: Tanto el token de acceso como el código de autorización se transmiten habitualmente en formato **JSON Web Token (JWT)**, que permite incluir información estructurada y firmada de forma segura.

3. ¿Dónde se aloja la información del usuario en un JWT ?

- La respuesta: b. PAYLOAD .
- Justificación: El **payload** del **JWT** contiene los *claims*, donde se almacena la información del usuario, tiempos de validez, roles y otros datos relevantes para la autorización.

MicroTest 6.4

Archivo: 031-Autenticación- TLS -Formularios.md

Idea clave: Tema 6 - Idea clave 4 (Autenticación TLS - basada en formularios)

Microtest: 6.4

1. TLS usa algoritmos como:

- La respuesta: d. Todos los anteriores son correctos.
- Justificación: TLS combina distintos tipos de algoritmos criptográficos según su función: RSA para cifrado asimétrico e intercambio de claves, AES para cifrado simétrico de los datos de la comunicación y SHA-512 para funciones hash que garantizan integridad.

2. La autenticación basada en formularios hace uso de:

- La respuesta: d. Todas las anteriores son correctas.
- Justificación: La autenticación por formularios requiere el envío de credenciales mediante método HTTP POST, valida usuario y contraseña en el servidor y, una vez autenticado, genera un ID de sesión que se convierte en la credencial activa del usuario.

3. ¿Qué se recomienda para TLS ?

- La respuesta: d. Todas las anteriores son correctas.
- Justificación: Las buenas prácticas de seguridad en TLS incluyen el uso de cifrados robustos como AES-256, claves asimétricas fuertes como RSA-2048 y, además, la autenticación mutua mediante certificados de cliente y servidor para prevenir ataques de intermediario y fortalecer la identidad de ambas partes.

MicroTest 6.5

Archivo: 032-Ataques-y-recomendaciones.md

Idea clave: Tema 6 - Idea clave 5 (Autenticacion: Recomendaciones)

Microtest: 6.5

1. ¿Qué tipo de ataques puede sufrir la autenticación para suplantar un usuario?
 - La respuesta: a. Fuerza bruta.
 - Justificación: La fuerza bruta intenta adivinar credenciales probando múltiples combinaciones hasta encontrar la correcta, lo que permite suplantar directamente al usuario. **LFI** y **SSRF** son vulnerabilidades de acceso o redirección de recursos, pero no están orientadas específicamente a la suplantación por autenticación.
2. ¿De qué tipo de ataque previene la implementación de **CAPTCHA** ?
 - La respuesta: a. Fuerza bruta.
 - Justificación: **CAPTCHA** está diseñado para diferenciar humanos de bots automatizados, evitando que herramientas automáticas puedan realizar miles de intentos de contraseñas en poco tiempo, que es precisamente la base del ataque de fuerza bruta.
3. ¿Qué medidas se recomiendan para implementar para tener una autenticación más robusta?
 - La respuesta: d. Todas las anteriores son correctas.
 - Justificación: Verificar la ruta de certificación mediante certificate pinning evita ataques **MITM**, combinar factores de autenticación incrementa la seguridad de identidad y requerir **TLS** de cliente añade verificación bidireccional y protección del canal, por lo que la suma de todas fortalece significativamente la autenticación.

MicroTest 7.1

Archivo: 034-Gestion-de-sesiones.md

Idea clave: Tema 7 - Idea clave 1 (Gestion de sesiones)

Microtest: 7.1

1. ¿Cuándo se debe crear el **ID** de sesión?
 - La respuesta: b. Después de la autenticación correcta.
 - Justificación: El **ID** de sesión solo debe generarse una vez que las credenciales del usuario han sido validadas por el servidor; hacerlo antes permitiría ataques de fijación de sesión donde un atacante podría forzar un identificador previamente conocido.
2. ¿Dónde puede ubicarse el **ID** de sesión?
 - La respuesta: d. Todas las anteriores.

- **Justificación:** El identificador de sesión puede enviarse mediante cabecera Set-Cookie, como parámetro en la URL o dentro del cuerpo de una petición POST, aunque la forma más segura recomendada es mediante cookies protegidas.
3. ¿Con qué método de autenticación se crea el ID de sesión?
- **La respuesta:** c. Basado en formularios.
 - **Justificación:** En la autenticación basada en formularios la aplicación valida usuario y contraseña y, tras ello, genera un identificador de sesión que se convierte en la credencial activa del usuario durante su interacción con el sistema.
-

MicroTest 7.2

Archivo: 035-Authorizacion.md

Idea clave: Tema 7 - Idea clave 2 (Autorizacion)

Microtest: 7.2

1. ¿Cómo se denomina la base de datos del mecanismo de autorización?
- **La respuesta:** a. Lista de control de acceso.
 - **Justificación:** La lista de control de acceso (ACL) es el componente donde se almacenan y consultan los permisos, roles y relaciones entre usuarios y recursos. Funciona como la “base de datos lógica” del sistema de autorización porque ahí se verifica quién puede acceder a qué.
2. ¿Con qué tipo de usuario se ejecuta un proceso relativo a un sitio web o plugin del navegador?
- **La respuesta:** c. Con un token restringido.
 - **Justificación:** Los navegadores modernos aíslan procesos usando tokens restringidos para limitar privilegios. Esto evita que un plugin o pestaña comprometida tenga acceso total al sistema operativo, aplicando el principio de mínimos privilegios.
3. ¿Qué se comprueba en la lista de control de acceso para permitir el acceso a un recurso a un usuario?
- **La respuesta:** a. Si el usuario posee el rol necesario que requiere el recurso para set accedido.
 - **Justificación:** El mecanismo de autorización compara el rol o permisos del usuario contra los requisitos del recurso. Si coincide con el rol permitido en la ACL, se concede acceso; de lo contrario, se deniega.
-

MicroTest 7.3

Archivo: 036-Autorizacion-recomendaciones.md

Idea clave: Tema 7 - Idea clave 3 (Autorizacion: Recomendaciones)

Microtest: 7.3

1. ¿Cuál es un ataque a la autorización?

- **La respuesta:** d. Todos los anteriores.
- **Justificación:** TOCTOU , XSS y LFI pueden explotarse para evadir o romper controles de autorización. Todos permiten acceder o manipular recursos sin los permisos adecuados, ya sea por condiciones de carrera, robo de sesión o acceso indebido a archivos.

2. ¿Cuál de los siguientes es un mecanismo de defensa para una buena autorización?

- **La respuesta:** d. Todas las anteriores.
- **Justificación:** Una política robusta de contraseñas, la separación de roles y la administración correcta de permisos son prácticas complementarias que fortalecen el sistema de autorización y reducen riesgos de escaladas de privilegios y accesos indebidos.

3. ¿A qué se debe el TOCTOU ?

- **La respuesta:** d. Las opciones A y B son correctas.
- **Justificación:** TOCTOU ocurre cuando no se diseñan operaciones atómicas y no se controlan adecuadamente los accesos a recursos, generando ventanas de tiempo entre la verificación y el uso que pueden ser explotadas para alterar estados o permisos.

MicroTest 8.1

Archivo: 038-Principios-del-Desarrollo-Seguro.md

Idea clave: Tema 8 - Idea clave 1 (Principios del desarrollo seguro)

Microtest: 8.1

1. ¿Qué no hay que usar para identificar usuarios?

- **La respuesta:** c. Opciones A y D.
- **Justificación:** No se deben usar ni correos electrónicos ni direcciones IP / MAC como identificadores únicos de usuario porque pueden cambiar, ser suplantados o no garantizar identidad real, lo que genera riesgos de seguridad y suplantación.

2. Señala la afirmación incorrecta sobre buenas prácticas de programación:

- **La respuesta:** b. Usar listas negras en lugar de blancas de comprobación.
- **Justificación:** Las listas negras son menos seguras porque solo bloquean valores conocidos, mientras que las listas blancas permiten únicamente valores explícitamente válidos, reduciendo significativamente el riesgo de inyección o entradas maliciosas.

3. Señalar la afirmación incorrecta sobre buenas prácticas de programación:

- **La respuesta:** c. Asumir que los usuarios no son maliciosos.

- **Justificación:** En seguridad siempre se debe asumir que cualquier usuario o entrada puede ser maliciosa. Confiar en el usuario rompe el principio de validación de entrada y aumenta la probabilidad de vulnerabilidades.

MicroTest 8.2

Archivo: 039-Owasp-top-ten-01.md

Idea clave: Tema 8 - Idea clave 2 (Desarrollo seguro: OWASP Top Ten I)

Microtest: 8.2

1. La mejor forma de evitar SQL injection es:
 - La respuesta: c. Mediante sentencias preparadas de SQL .
 - Justificación: Las sentencias preparadas separan la estructura de la consulta SQL de los datos del usuario, evitando que el input se interprete como código SQL ejecutable. Es la defensa principal recomendada por OWASP porque valida tipos y parámetros automáticamente, a diferencia de blacklist o validaciones solo del lado del cliente que pueden ser fácilmente evadidas.
2. ¿Cuáles son formas de prevención de XSS en el código?
 - La respuesta: d. Todas las anteriores son correctas.
 - Justificación: La prevención de XSS requiere un enfoque en capas: validar la entrada reduce datos maliciosos, codificar la salida impide la ejecución de scripts en el navegador y las cabeceras como XSS -Protection y Content Security Policy añaden una barrera adicional a nivel del navegador. Usar solo una técnica no es suficiente.
3. ¿Cuáles son formas de prevención de HTTP response splitting en el código?
 - La respuesta: d. Todas las anteriores son ciertas.
 - Justificación: El HTTP response splitting se previene combinando validación de entrada para bloquear caracteres CR / LF , codificación de salida para neutralizar caracteres especiales y controles adicionales como listas negras o filtros. La combinación de técnicas reduce significativamente la posibilidad de inyección en encabezados HTTP .

MicroTest 8.3

Archivo: 040-Owasp-top-ten-2.md

Idea clave: Tema 8 - Idea clave 3 (Desarrollo seguro: OWASP Top Ten II)

Microtest: 8.3

1. ¿Cómo se pueden evitar vulnerabilidades XXE ?
 - La respuesta: d. Todas las anteriores son ciertas.

- Justificación: Las vulnerabilidades **XXE** se mitigan combinando varias defensas: validar entradas en el código, validar contra un **XSD** para restringir la estructura y, especialmente, deshabilitar **DTD** . Cada medida reduce un vector distinto de ataque, por lo que lo correcto es aplicar todas.
2. ¿Qué se recomienda a la hora de generar números aleatorios?
- La respuesta: b. Usar algoritmos de tipo criptográfico.
 - Justificación: Los algoritmos estadísticos comunes son predecibles y no aptos para seguridad. Los criptográficos están diseñados para ser impredecibles y se usan en tokens, contraseñas y sesiones. La longitud por sí sola no garantiza seguridad si el generador es débil.
3. ¿Cómo se denomina en Java la función segura de generación de números aleatorios?
- La respuesta: b. `SecureRandom()` .
 - Justificación: En Java la clase segura es **SecureRandom**, pensada para usos criptográficos. Las otras opciones son incorrectas o corresponden a generadores no seguros.
-

Microtest 8.4

Archivo: 041-Owasp-top-ten-3.md

Idea clave: Tema 8 - Idea clave 4 (Desarrollo seguro: **OWASP** Top Ten **III**)

Microtest: 8.4

1. Señalar la afirmación incorrecta
- La respuesta: a.
 - Justificación: Es incorrecta porque **sí existe riesgo al usar librerías de terceros**; pueden contener vulnerabilidades públicas (**CVE**) y no se puede asumir que son seguras sin auditoría y actualización.
2. ¿Cómo no se debe acceder (mediante autenticación) a una base de datos desde el código?
- La respuesta: b.
 - Justificación: **Codificar usuario y contraseña en el código fuente (hardcoded)** es una mala práctica grave de seguridad, ya que cualquiera con acceso al código o al binario podría extraer las credenciales.
3. ¿Qué función hay que usar en lugar de `eval()` ?
- La respuesta: c.
 - Justificación: `json.parse()` valida y convierte texto **JSON** de forma segura, mientras que `eval()` ejecuta código arbitrario y puede permitir inyección de scripts o ejecución maliciosa.
-

MicroTest 8.5

Archivo: 042-Open-redirect-csrf-ssrf.md

Idea clave: Tema 8 - Idea clave 5 (Desarrollo seguro: Open redirect y CSRF)

Microtest: 8.5

1. Señalar la afirmación correcta para evitar Open Redirect

- La respuesta: c.
- Justificación: Open Redirect se produce por **redirigir a URLs controladas por el usuario sin validación**; la medida correcta es **validar contra una lista blanca de URLs permitidas**, no basta con validar en cliente ni con codificar salida.

2. Señalar la afirmación correcta para evitar CSRF

- La respuesta: a.
- Justificación: CSRF se previene mediante **tokens anti-CSRF únicos por sesión o petición**, que el servidor compara antes de ejecutar acciones sensibles; codificar salida o listas blancas no mitigan este tipo de ataque.

3. ¿A qué corresponde la siguiente línea de código?:

```
req.getParameter("_csrf_token").equals(req.getSession().getAttribute("_csrf_token"))
```

- La respuesta: d.
- Justificación: Esa línea **compara el token enviado en la petición con el token almacenado en la sesión**, que es exactamente el mecanismo de **verificación de un token anti-CSRF** para asegurar que la solicitud es legítima.

MicroTest 9.1

Archivo: 044-Analisis-de-app-web.md

Idea clave: Tema 9 - Idea clave 1 (Analysis de seguridad de las aplicaciones web)

Microtest: 9.1

1. ¿En qué fase del SSDLC se debe usar una herramienta SAST ?

- La respuesta: b. Desarrollo.
- Justificación: SAST analiza el código fuente sin ejecutar la aplicación, por lo que su objetivo es detectar vulnerabilidades tempranas mientras se está programando, antes de desplegar el sistema.

2. ¿En qué fase del SSDLC se debe usar una herramienta DAST ?

- La respuesta: d. Pruebas.
- Justificación: DAST evalúa la aplicación en ejecución desde el exterior (caja negra), lo cual solo es posible cuando la aplicación ya está desplegada en un entorno de prueba o staging.

3. ¿En qué fase del SSDLC se debe usar una herramienta IAST ?

- La respuesta: d. Pruebas.
 - Justificación: IAST requiere que la aplicación esté ejecutándose y además necesita interacción del auditor y sensores internos, lo cual se realiza típicamente en entornos de prueba donde se validan comportamientos reales del sistema.
-

MicroTest 9.2

Archivo: 045-Analisis-seguridad-estatico.md

Idea clave: Tema 9 - Idea clave 2 (Analysis de seguridad estatico de codigo fuente)

Microtest: 9.2

1. ¿Qué tipo de análisis puede realizar una herramienta SAST para comprobar las interacciones entre distintas funciones?
 - La respuesta: d. Todos los anteriores.
 - Justificación: Una herramienta SAST puede realizar análisis intraprocedural (dentro de una función), interprocedural (entre funciones) y semántico (significado y lógica del código). Para comprobar correctamente las interacciones entre funciones necesita apoyarse en todos estos niveles de análisis en conjunto.
 2. En cuanto a herramientas de análisis de la seguridad SAST, señalar la afirmación falsa:
 - La respuesta: d. Todas las anteriores son falsas.
 - Justificación: Las opciones a, b y c son afirmaciones verdaderas sobre SAST (no cubren dependencias de terceros directamente, tienen falsos positivos/negativos y algunas pueden analizar bytecode o ejecutables), por lo tanto no es cierto que sean falsas.
 3. ¿Qué se puede hacer con los falsos positivos posibles en el resultado de análisis de una herramienta SAST?
 - La respuesta: a. Auditar las vulnerabilidades del informe.
 - Justificación: Los falsos positivos deben revisarse manualmente para confirmar si la vulnerabilidad existe realmente, ya que SAST es un proceso semi-automático que requiere validación humana.
-

MicroTest 9.3

Archivo: 046-Analisis-de-seguridad-Dast.md

Idea clave: Tema 9 - Idea clave 3 (Analysis de seguridad funcional y dinamico)

Microtest: 9.3

1. Señalar la afirmación falsa:

- La respuesta: c. Las herramientas de tipo **IAST** normalmente no tienen impacto en el rendimiento.
 - Justificación: **IAST** instrumenta la aplicación en tiempo de ejecución mediante agentes o sensores internos, lo que sí puede generar impacto en rendimiento, aunque sea moderado.
2. Las herramientas de tipo **IAST** pueden instrumentar:
- La respuesta: c. El código ejecutable.
 - Justificación: **IAST** inserta instrumentación en el bytecode o código compilado que se está ejecutando, no en el código fuente directamente ni únicamente en tráfico externo.
3. ¿Qué tipo de análisis realiza una herramienta de tipo **DAST** ?
- La respuesta: a. Semántico.
 - Justificación: **DAST** analiza el comportamiento de la aplicación en ejecución y el significado de las respuestas ante distintas entradas y payloads, no revisa sintaxis ni estructura interna del código, sino la lógica observable desde el exterior.
-

MicroTest 10.1

Archivo: 048-Firewall-app-web.md

Idea clave: Tema 10 - Idea clave 1 (Firewall de aplicaciones web)

Microtest: 10.1

1. Un **WAF** detecta y bloquea ataques web usando:
- La respuesta: a. Expresiones regulares.
 - Justificación: Los **WAF** analizan peticiones **HTTP** comparándolas con **patrones y firmas** de ataques conocidos, comúnmente implementados mediante expresiones regulares que permiten identificar cadenas maliciosas como **SQL Injection** o **Path Traversal**.
2. ¿Qué tipo de instalación de un **WAF** solo detecta y no bloquea un ataque?
- La respuesta: c. Pasivo.
 - Justificación: En modo o instalación **pasiva** el **WAF** únicamente monitoriza y registra el tráfico, generando alertas o logs, pero no interviene en la comunicación ni bloquea peticiones maliciosas.
3. ¿Qué tipo de instalación es la más recomendable para un **WAF** ?
- La respuesta: b. Proxy reverso.
 - Justificación: El modo **proxy reverso** coloca al **WAF** delante de la aplicación, permitiendo inspeccionar, filtrar y bloquear tráfico antes de que llegue al servidor, ofreciendo mayor control y nivel de protección que otros modos.
-

MicroTest 10.2

Archivo: 049-Headers-http.md

Idea clave: Tema 10 - Idea clave 2 (Cabeceras de seguridad HTTP)

Microtest: 10.2

- ¿Qué valor se recomienda para la cabecera X- `FRAME` - `OPTIONS` ?
 - La respuesta: d. `DENY`.
 - Justifacion: `DENY` impide completamente que la página se cargue dentro de iframes en cualquier dominio, ofreciendo la máxima protección contra ataques de **clickjacking**.
- ¿Qué valor se recomienda para la cabecera `CONTENT` - `SECURITY` - `POLICY` ?
 - La respuesta: a. `default-src 'self'`.
 - Justifacion: `default-src 'self'` limita la carga de recursos únicamente al **mismo dominio**, reduciendo riesgos de `XSS` e inyección de contenido externo malicioso.
- ¿Qué valor se recomienda para el parámetro `SAMESITE` de la cabecera `SET` - `COOKIE` ?
 - La respuesta: a. `STRICT`.
 - Justifacion: `SameSite=Strict` evita que la cookie se envíe en peticiones desde otros dominios, protegiendo contra `CSRF` y robo de sesión al restringir completamente el uso cross-site.

MicroTest 10.3

Archivo: 050-Seguridad-en-apps- RIA .md

Idea clave: Tema 10 - Idea clave 3 (Seguridad en aplicaciones RIA)

Microtest: 10.3

- La vulnerabilidad `XSS` `DOM` se puede evitar mediante:
 - La respuesta: d. Todas las anteriores son correctas.
 - Justifacion: Porque el `XSS` basado en `DOM` se mitiga aplicando varias capas de seguridad: validación de entrada para impedir datos maliciosos, codificación de salida para que el navegador no ejecute scripts y cabeceras como `XSS` - `PROTECTION` que añaden un filtro adicional en algunos navegadores.
- El ataque Javascript hijacking es similar en tecnología `AJAX` a:
 - La respuesta: b. `CSRF`.
 - Justifacion: Porque ambos ataques aprovechan la sesión activa del usuario en el navegador para ejecutar peticiones o extraer información sin su consentimiento, reutilizando credenciales y cookies válidas.
- ¿Cómo se puede saltar/evitar la política del mismo origen?
 - La respuesta: d. Todas las anteriores son correctas.

- Justificación: Porque etiquetas como `<script>` , `<iframe>` o `<img>` pueden cargar recursos desde otros dominios y permiten técnicas que evitan la restricción de la Same Origin Policy si no existen controles adicionales como `CSP` o `CORS` .